Denial of Service (DoS) Lab — SYN Flood su Metasploitable2

Tool utilizzato: hping3
Target: Metasploitable2 (192.168.1.19)
Ambiente: Kali Linux (192.168.1.21), VM UTM su Apple Silicon

Nota etica/metodologica: l'attacco è stato condotto esclusivamente contro Metasploitable2, una macchina virtuale distribuita apposta per la pratica di sicurezza offensiva/difensiva, su una rete locale isolata, senza alcun impatto su sistemi di terzi. Un attacco DoS/DDoS verso un sistema non autorizzato è illegale in Italia e nella maggior parte delle giurisdizioni.

Obiettivo:

Sperimentare in autonomia un attacco Denial of Service di tipo SYN flood contro un servizio di rete esposto da Metasploitable2, osservando l'effetto generato sia dal lato attaccante (Kali) sia dal lato vittima (traffico di rete e carico di sistema), per comprendere concretamente il funzionamento e l'impatto di questa classe di attacco.

Metodologia:

Lab condotto in autonomia, verificato e documentato a posteriori tramite registrazione della sessione terminale (comando script) sul lato Kali, più osservazione diretta del lato Metasploitable2 tramite screenshot.

1. Identificazione degli indirizzi IP

Comando (Kali):

```
ip addr
```

Output (estratto rilevante):

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> ...
inet 192.168.1.21/24 brd 192.168.1.255 scope global dynamic
noprefixroute eth0
```

Risultato: Kali (attaccante) = `192.168.1.21`, Metasploitable2 (vittima, da VM) = `192.168.1.19`, verificato con `ifconfig` lato vittima.

2. Verifica di raggiungibilità

Prima di qualunque azione offensiva, verificata la raggiungibilità del target e misurata la latenza di base — utile come termine di paragone per valutare l'impatto dell'attacco in seguito.

Comando:

```
ping -c 4 192.168.1.19
```

Output:

```
PING 192.168.1.19 (192.168.1.19) 56(84) bytes of data.
64 bytes from 192.168.1.19: icmp_seq=1 ttl=64 time=8.59 ms
64 bytes from 192.168.1.19: icmp_seq=2 ttl=64 time=2.42 ms
64 bytes from 192.168.1.19: icmp_seq=3 ttl=64 time=2.41 ms
64 bytes from 192.168.1.19: icmp_seq=4 ttl=64 time=2.29 ms

--- 192.168.1.19 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3018ms
rtt min/avg/max/mdev = 2.285/3.925/8.586/2.691 ms
```

Interpretazione: host raggiungibile, 0% di perdita pacchetti, latenza media ~3.9 ms — condizione di rete sana, baseline utile per il confronto post-attacco.

3. Scansione dei servizi esposti

Eseguita una scansione con rilevamento versione per individuare un servizio target concreto su cui indirizzare l'attacco, invece di colpire una porta a caso.

Comando:

```
nmap -sV 192.168.1.19
```

Output (estratto):

```
Not shown: 977 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4
22/tcp open ssh OpenSSH 4.7p1
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
... (altre 19 porte aperte, coerenti con i lab di enumerazione
precedenti)
```

Scelta del target: porta 80/tcp (HTTP, Apache) — servizio web, bersaglio tipico e realistico per un SYN flood dimostrativo.

4. Lancio dell'attacco SYN flood

hping3 è un tool per la costruzione e l'invio di pacchetti TCP/IP personalizzati. Con i flag usati, genera un flusso continuo di pacchetti TCP con solo il flag SYN impostato (il primo passo del three-way handshake TCP), senza mai completare la connessione.

Comando:

```
sudo hping3 -S --flood -p 80 192.168.1.19
```

Spiegazione dei flag:

- `-S` → Imposta il flag SYN sui pacchetti inviati (richiesta di apertura connessione TCP)
- `--flood` → Invia pacchetti alla massima velocità possibile, senza attendere risposte né rispettarne il ritmo
- `-p 80` → Porta di destinazione — qui la 80/HTTP individuata con Nmap
- `192.168.1.19` → Indirizzo IP del target (Metasploitable2)

Output (attacco interrotto manualmente con Ctrl+C dopo alcuni secondi):

```
HPING 192.168.1.19 (eth0 192.168.1.19): S set, 40 headers + 0 data
bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.1.19 hping statistic ---
238830097 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

Interpretazione importante: il "100% packet loss" qui non indica un fallimento dell'attacco, né un errore. In modalità --flood , hping3 non attende né mostra le risposte — è un comportamento atteso, dichiarato esplicitamente nel messaggio "no replies will be shown". La metrica realmente significativa è il numero di pacchetti trasmessi: oltre 238 milioni di pacchetti SYN in pochi secondi, un volume sufficiente a saturare la coda di connessioni TCP in attesa (SYN queue) del servizio target.

5. Osservazione lato vittima — cattura del traffico

In parallelo, sulla VM Metasploitable2, catturato il traffico diretto alla porta 80 per confermare l'arrivo effettivo del flood.

Comando (su Metasploitable2):

```
sudo tcpdump -n -i eth0 'tcp port 80'
```

Il filtro 'tcp port 80' limita la cattura al solo traffico TCP sulla porta 80, isolando il rumore del resto della rete e mostrando esclusivamente il flusso di pacchetti SYN in arrivo dall'attacco.

6. Osservazione lato vittima — carico di sistema

Eseguito top su Metasploitable2 durante l'attacco, per osservare l'effetto sul carico del sistema.

Output (estratto, valori che cambiano continuamente in tempo reale durante l'attacco):

```
load average: 14.59, 12.56, 6.28
Cpu(s): 5.6%us, 1.7%sy, 92.7%id
Mem: 515380k total, 293680k used, 221700k free
```

Interpretazione: il load average (14.59 sulla media a 1 minuto) è molto elevato per una macchina con le risorse di Metasploitable2 — un valore ben oltre il numero di CPU disponibili indica un sistema sotto pressione, con processi in coda di attesa. Da notare che la CPU risultava comunque per lo più idle (92.7%) nel momento dello screenshot: è un pattern tipico di un SYN flood, il cui impatto principale è sulla gestione delle connessioni di rete (kernel/stack TCP, coda SYN) più che sul calcolo puro della CPU — il sistema fatica a gestire il volume di richieste di connessione, non a "calcolare" qualcosa.

Conclusioni:

L'esperimento ha dimostrato concretamente il meccanismo di un SYN flood: un volume di richieste di connessione TCP incomplete, sufficiente a generare un carico di sistema anomalo sulla vittima (load average elevato) senza che sia necessaria risposta o completamento della connessione da parte dell'attaccante. La differenza tra ambiente di rete sano (ping iniziale, 0% loss) e sistema sotto attacco (load average alle stelle) è il punto didattico centrale del lab.

Cosa ho imparato:

- Differenza tra un semplice scan di raggiungibilità/servizi (ping, Nmap) e un vero test di stress del sistema (hping3)
- Funzionamento di un SYN flood: invio di pacchetti SYN senza completare il three-way handshake TCP, per saturare la coda di connessioni in attesa
- Interpretazione corretta del "100% packet loss" in modalità flood di hping3 — comportamento atteso, non un errore o un fallimento
- Lettura del load average su un sistema Linux sotto stress di rete, e perché può essere alto anche con CPU in gran parte idle
- Importanza di osservare un attacco da entrambi i lati (attaccante e vittima) per comprenderne davvero l'impatto

Lab condotto interamente in autonomia, documentato e verificato a posteriori tramite registrazione della sessione terminale lato Kali (comando script) e screenshot diretto della VM Metasploitable2 durante l'attacco.